

Bayyina بيّنة

Evidence-based third-party vendor assurance for government contracts

Topic

Third-Party / Vendor Risk Assessment
Automation for Government Contracts

Team VoidHack
Captain Piyush Goeel

A government buyer decides which supplier to trust using a document the supplier wrote about itself. **Bayyina treats that document as a set of hypotheses rather than a filing.** It tests every questionnaire answer that can be tested against externally observable evidence, estimates how far the untestable remainder can be relied on, refuses to rank bidders whose evidence cannot separate them, detects upstream dependencies shared across the bid field, and ends in drafted contract conditions with named acceptance tests.

48%

of breaches now involve a third party — up from 30% in 2025 and 15% in 2024
Verizon DBIR 2026, n > 22,000 breaches across 145 countries

\$8.45M

average cost of a supply-chain-compromise breach in the Middle East, against a \$4.99M global all-breach average
IBM Cost of a Data Breach, Middle East findings, 3 August 2026

14%

of third-party risk professionals are highly confident that vendor questionnaire answers are accurate — while 84% rely on them
Cyentia Institute / RiskRecon, State of Third-Party Risk Management

WHAT IS IN THIS SUBMISSION

- **A working prototype.** Python, **zero runtime dependencies**, standard library only.
- **One command to reproduce.** `pip install -e . && bayyina assess --tender scenarios/MDG-2026-114`
- **A complete demonstration tender.** Three bidders, 45 recorded observations, runs fully offline.
- **122 tests** in 0.3 s, including a suite dedicated to *gaming* the tool — adversarial input, and every way a bidder could profit from a defective submission.
- **A verifiable evidence ledger.** Hash-chained; editing one stored record is detected and named.
- **Reports** — an award dashboard and a one-page assessment per bidder, self-contained HTML.
- **docs/EVIDENCE.md** — every external claim in this deck with its source and how far we verified it.
- **A live mode.** `bayyina live --domain <domain>` runs the identical pipeline against real infrastructure.

THE NAME

Bayyina (بيّنة) is the Arabic legal term for clear, produced evidence — the standard a claim must meet before it is relied on. That is the design brief in one word: an assertion is not evidence until something tests it.

TWO THINGS WE WILL NOT DO

We do not fit a model. A model trained on public breach disclosures learns disclosure, not compromise. There is no training set here, and therefore no leakage.

We do not call the output a risk measure. It is an ordinal ranking and triage device, and every report says so.

RUN THE PROTOTYPE YOURSELF
github.com/pi-24/bayyina

```
git clone https://github.com/pi-24/bayyina.git && cd bayyina
pip install -e . # no dependencies, Python 3.9+
bayyina assess --tender scenarios/MDG-2026-114 # runs offline
```

Apache-2.0, ~5,900 lines, **no third-party dependencies**. A clean clone runs the full assessment offline and passes **122 tests in 0.3 s**. Every figure in this deck is a screenshot of that command's real output — nothing here is a mockup.

WHERE TO FIND EACH THING THE JURY SCORES

CRITERION	WEIGHT	WHERE IT IS ADDRESSED IN THIS DECK	WHAT TO RUN OR READ IN THE REPOSITORY
Fit to the brief and the business problem	20%	Page 2 — who buys it, what it replaces, and the three UAE procurement-law obligations behind the design	README.md · docs/EVIDENCE.md \$1, \$5
Relevance of the proposed solution	15%	Page 2 (why questionnaires fail, what a rating costs) and page 3 (FedRAMP 20x, the CMMC suspension)	docs/EVIDENCE.md \$2, \$3, \$4
Does the prototype work	25%	Page 4 — reproducibility, the offline demonstration, 122 tests, and the ledger tamper test	bayyina assess · bayyina reproduce · pytest -q
Technical depth and correctness	25%	Page 3 (scoring model, three-state epistemics) and page 4 (no fitted model, Wilson, sensitivity)	bayyina/scoring.py · stats.py · divergence.py
Innovation	15%	Page 3, contributions 1–5 — divergence, the reliability estimator, refusing to rank, concentration, contract conditions	bayyina/divergence.py · concentration.py · contract.py

Project objective

The problem

Security due diligence in public procurement is a document exchange. The buyer sends a questionnaire, the supplier answers it about itself, an evaluator files it. Nothing in that loop tests whether any answer is true, and the supplier that writes the best document wins.

Meanwhile the supplier is now the way in. Third-party involvement in breaches went **15% → 30% → 48%** across three consecutive Verizon DBIRs. Government suppliers are worse than average: **58% of breaches at the top 100 US federal contractors involved a third-party vector, against the ~29% global figure in the same study — roughly double.**

DBIR 2024/25/26 · SecurityScorecard, 22 Jan 2025

THE REGIONAL SHAPE OF IT

Of the **30 largest UAE companies by revenue, 90% score A or B on their own security posture — and 73% have a supplier that has been breached.** The same study found 73% also have a breached fourth party.

Own-posture assurance is not supply-chain assurance. An organisation can be in excellent shape and still be reached through a supplier it assessed with a PDF. That gap is the product.

SecurityScorecard UAE supply chain study, 11 Feb 2024 · IBM MEA, Aug 2026: supply chain compromise was 16% of Middle East breaches at \$8.45M average cost

WHO BUYS IT, WHO RUNS IT

Buyer: the procurement and information-security functions of a government entity. **Operator:** the technical evaluator on a tender panel. **Deployment:** a Python package the entity runs inside its own environment — no data leaves, no subscription, no per-vendor fee. **When:** at bid evaluation, and again as the acceptance test for each contract condition.

Why the current control does not work

84% of firms use questionnaires to assess vendor security

81% report that most vendors claim *perfect* compliance

14% are highly confident those answers are accurate

Near-universal use. Near-universal passing. Near-zero belief. The Cloud Security Alliance — which authors the CAIQ questionnaire — publishes the same critique itself: responses *“only represent a single point in time”* and *“are rarely evaluated.”*

Cyentia/RiskRecon (n=154, 2020 — old and small, and we say so) · CSA, 2 Apr 2025

WHAT BAYYINA REPLACES

- **Manual questionnaire triage.** 5–15 hours to complete one, and often nobody reads it. Bayyina tests the testable subset in seconds and puts a named human only where judgement is genuinely required.
- **The external-signal half of a commercial security rating.** Roughly 71.5% of a Bitsight rating is externally observable configuration; UpGuard's is explicitly 50% automated scanning. Reported market price is **\$150–400 per vendor per year with a \$12–25k floor** — economically absurd for a buyer assessing three bidders on one contract.
- **The gap nothing currently fills:** comparing bidders against *each other*, and testing what each one claimed.

Bitsight and UpGuard published methodologies · pricing from Vendr negotiated-deal aggregation, not vendor list prices

What UAE law already requires — and a questionnaire cannot deliver

Federal Law No. 11 of 2023 on Procurement in the Federal Government

- **Art. 22(3)** — non-financial evaluation criteria must be *“objective ... and quantifiable as much as possible.”* A questionnaire yes/no is neither.
- **Art. 22(4)** — the tender must publish *“the weight assigned to each criterion”* in advance. So in Bayyina weights live in the buyer's tender file, never in the tool, and every report prints the set that was used.
- **Art. 29** — a failed bidder may request *“the weaknesses and strengths of its bid.”* So every finding keeps the raw observation that produced it, and the per-bidder report is written to be handed over.

UAE National Cloud Security Policy requires organisations to *“identify security risks from third-party suppliers and require independent security testing rather than relying solely on provider assertions.”*

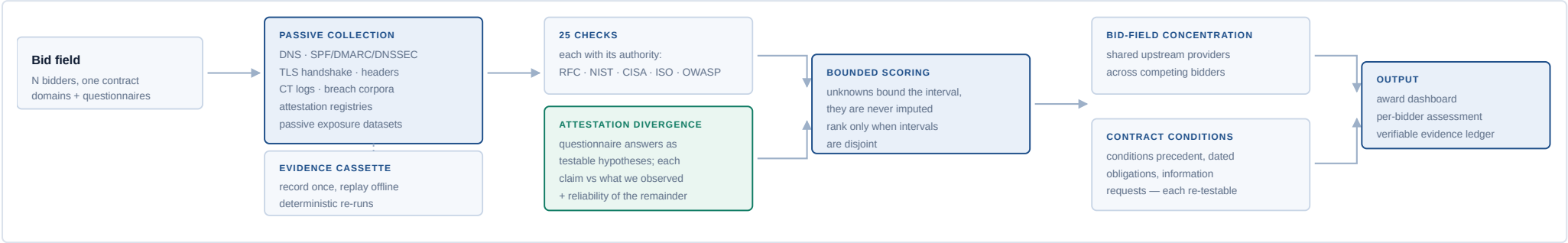
Dubai DESC ISR v3 extends obligations to *“consultants, contractors”* and to *“external party and managed services”*, with Third Party Management as a named domain. The UAE Information Assurance Standard carries a Third Party Security control family.

Ministry of Finance PDF · Pinsent Masons analysis of the Cloud Security Policy · DESC ISR v3.0 announcement. Full sourcing and confidence levels in docs/EVIDENCE.md

AGAINST THE TWO THINGS A GOVERNMENT BUYER USES TODAY

CAPABILITY	SECURITY QUESTIONNAIRE	COMMERCIAL SECURITY RATING	BAYYINA
Tests whether the supplier's answers are true	NO it is the answer	NO never sees the questionnaire	YES 15 predicates, claim by claim
Declines to rank when the evidence cannot separate two bidders	N/A	NO always emits a number	YES disjoint-interval rule; unobserved checks widen it
Compares bidders against <i>each other</i> , and finds shared upstream providers	NO	NO rates one company at a time	YES DNS, mail, edge and CA across the field
Sees active compromise — botnet, C2 and sinkhole telemetry	NO	YES ~26% of a Bitsight rating	NO no sensor network — and we say so
Cost to assess three bidders on one contract	5–15 analyst hours per questionnaire, often unread	\$12–25k floor; \$150–400 per vendor per year at volume	Free, self-hosted; no data leaves the buyer

Proposed solution



1. The questionnaire becomes testable

Each answer carries a named predicate. A bidder that answered “we enforce DMARC” has made a claim one DNS lookup refutes. **A contradiction is weighted above the underlying control gap:** a missing DMARC record is a hygiene weakness, but a *claim* of enforcement with p=none published is an accuracy failure in a document the bidder signed and the buyer is relying on.

2. The untestable remainder gets a number

Most of a questionnaire cannot be checked from outside — background screening, key management, backup restoration. But the testable claims are a **sample**, and how they fare measures how far to trust the rest. Reported as a **Wilson score interval** over *independent evidence sources*, not over claims — three attestations can be tested against one HTTP response, and counting those as three trials would report an interval narrower than the evidence supports.

3. Unknowns bound the score; they are never imputed

Every score is an interval: the lower bound assumes every unobserved check would have failed, the upper that every one would have passed. **A bidder is ranked above another only when its lower bound exceeds the other's upper bound**, and a tier boundary holds only if *every* member of a tier dominates *every* member below — otherwise the tiers merge. No prior, no distribution, nothing to attack.

4. The bid field, not just the bidder

DORA Art. 29 asks one buyer about concentration across *its own* portfolio. Nobody asks it across a *tender*. A buyer splitting an award between two bidders that terminate TLS at the same CDN and route mail through the same provider has bought two invoices and one failure domain — invisible to every commercial rating, because each rates one company alone.

5. It ends in contract language

An assessment ending in a score changes nothing. Each finding becomes a drafted obligation with a window sized by severity and contract criticality, and **a named acceptance test — re-running the check that produced it**. Three classes: conditions precedent to award, dated contract conditions, and information requests routed to a named reviewer.

Why this, why now

FedRAMP 20x is replacing static narrative assessment with Key Security Indicators — machine-readable, continuously validated assertions; Phase 3 began April 2026. In the other direction, **CMMC Phase II was suspended in July 2026**, with the cost and burden of mandatory third-party certification on small suppliers given as the reason. Government assurance is moving from attestation documents to machine-checkable evidence, and it has to get cheaper while doing it.

SCOPE POLICY — ENFORCED IN THE TRANSPORT LAYER, NOT JUST DOCUMENTED

DNS over HTTPS, one TLS handshake, one HTTPS GET per endpoint, and public datasets. **There is no primitive in this codebase for port scanning, vulnerability probing, authentication attempts, fuzzing or zone transfer.** That is a legal position as much as an engineering one: the UK Computer Misuse Act 1990 s.1 has no statutory research defence and the status of port scanning is unresolved, and the US DOJ’s 2022 CFAA charging policy is prosecutorial policy rather than statute and confers no civil immunity. Restricting the tool to observations a bidder’s own customers make every day is what lets a buyer run it across a bid field without per-bidder authorisation.

EXPOSED SERVICES, READ RATHER THAN SCANNED

The brief asks for exposed services, and enumerating them ourselves would mean port scanning. That enumeration has already been done, publicly and continuously, by internet-wide measurement projects — so the buyer supplies a passive export (Censys, Shodan, Rapid7 Open Data, or its own attack-surface inventory) and Bayyina **reads the observation rather than making it**. Zero packets reach the bidder, and the finding still carries a timestamp, a named source and a raw record the bidder can dispute. With no dataset supplied the check returns **unknown**, never clean — the requirement visibly unmet rather than quietly assumed away.

THREE STATES, NOT TWO

Most tools have pass and fail. Bayyina distinguishes **unknown** (the control applies, we could not observe it — widens the interval), **not applicable** (nothing for the control to bite on, such as disclosure timeliness for a vendor with no incidents — leaves the denominator, so a clean vendor is not punished with uncertainty it did not earn), and **needs human** (no machine can decide whether an ISO 27001 scope statement covers the delivering entity — so it goes to a named reviewer, never to a silent pass). Conflating any two of these is how a scoring tool quietly tells a buyer something it does not know.

Solution validation

DOES IT RUN, AND DOES IT RUN TWICE?

```
$ bayyina reproduce --tender scenarios/MDG-2026-114
run 1: ledger head 142e94cca9a8... digest 08e678bb...
run 2: ledger head 142e94cca9a8... digest 08e678bb...

Identical. Same cassette in, same evidence
chain and same scores out.
```

Determinism is **proved, not claimed**. Timestamps come from the evidence rather than the wall clock, evidence is hashed through canonical JSON, and the ledger is written in sorted order. Certificate expiry is measured against the observation date, so a replay gives the same answer next year as it did today.

REPRODUCE IT YOURSELF, IN THIS ORDER

```
$ git clone https://github.com/pi-24/bayyina.git
$ pip install -e . # no dependencies
$ bayyina assess --tender scenarios/MDG-2026-114
$ bayyina reproduce --tender scenarios/MDG-2026-114
$ bayyina verify-ledger out/.../evidence-ledger.jsonl
$ bayyina checks --check DNS-002
$ python -m pytest -q
$ bayyina live --domain <a-real-domain>
```

Python 3.9+. Nothing to configure, no API key, no network needed for anything except the last line.

RECORD / REPLAY — WHY THE OFFLINE DEMO IS HONEST

Evidence collection and evidence use are separate layers. A **cassette** is a recorded set of raw observations with the timestamp each was taken at. `--mode replay` performs no network activity; `--mode record` collects live.

The **scoring pipeline cannot tell the difference**. The run reproduced offline executes exactly the same check, scoring, divergence, concentration and reporting code as a live run — only the transport differs. Nothing in the analysis path is stubbed for the demonstration.

TESTS — 122, IN 0.3 SECONDS

Scoring invariants	the point estimate can never fall outside its bounds; an unknown widens the interval without moving the estimate; zero evidence yields the full range
Adversarial input	null bytes, 5,000-character records, emoji, SQL and path traversal strings, HTML injection, Arabic text — every parser is asserted to never read garbage as a passing control
Failure direction	a check that raises must not abort the run, and must not produce a PASS; a questionnaire that will not parse must leave the bidder unrankable, never approved
Ledger integrity	edit, delete or reorder a record — each is detected separately and named
Statistics	Wilson checked against hand-computed values; bounds stay inside [0,1] at the extremes where the normal approximation fails; a perfect small sample must not read as certainty; clustering must never <i>narrow</i> an interval
Anti-gaming	a corrupt questionnaire must lower a bidder's upper bound, never raise it; a wide-interval bidder must not split the field into tiers its own pairwise table denies; a typo in a weight name must be reported, not silently absorbed

Tamper test

One stored DMARC record edited to claim an enforcing policy:

```
Chain does NOT verify.
! record 6 (evidence): payload does not
match its hash — the stored evidence was
modified after it was recorded
```

Stated precisely: this is **tamper-evidence**, not tamper-proofing. Anyone holding the file can rewrite the whole chain. It defends against silent mutation of a stored assessment, which is the realistic procurement risk; defending against a malicious operator needs a countersignature from a party who does not control the file.

IS THE METHOD CORRECT?

No machine learning, deliberately. There is no adequate labelled dataset: a model trained on public breach disclosures learns *disclosure*, not compromise. Sarabi et al. (*Journal of Cybersecurity*, 2016) predicted disclosed breaches at ~90% TP / 11% FP from **business-profile data alone** — industry, size, traffic rank, no security measurements at all. A technical rating performing similarly may be reproducing firmographics. **Nothing here is fitted, so there is no train/test split and no leakage.**

The composite is declared ordinal. Multiplying ordinal severities and calling the product "risk" is not quantification — there is no unit. Bayyina claims a ranking and triage device and says so in every report. The one probabilistic statement it makes carries an interval and a named estimator.

The weights are not load-bearing, and we measure it. 2,000 Dirichlet-perturbed weight vectors ($\alpha = 40 \times \text{weight}$, seeded so the figure reproduces) plus a leave-one-criterion-out analysis: the leader is unchanged in **100%** of samples and under every single criterion removal. This measures the stability of the *indicative point order* — the dominance tiers do not turn on the weighting in the same way — and bidders with no point estimate are excluded rather than sorted last on a sentinel.

What it cannot do

No sinkhole or darknet telemetry, so **no visibility of active compromise** — roughly a quarter of a commercial rating that we do not have. **ISO 27001 scope adequacy cannot be automated**, and is routed to a human. **SOC 2 cannot be verified at all** beyond the CPA firm: it is a private attestation with no registry. **Absence from IAF CertSearch is not evidence of a false certificate** — DAkkS, Germany's national accreditation body, publicly declined to apply IAF MD 28:2023 on 15 Nov 2024. Breach history measures *disclosed* breaches, so a clean record is weak evidence of safety. Every one of these is printed in the output rather than hidden.

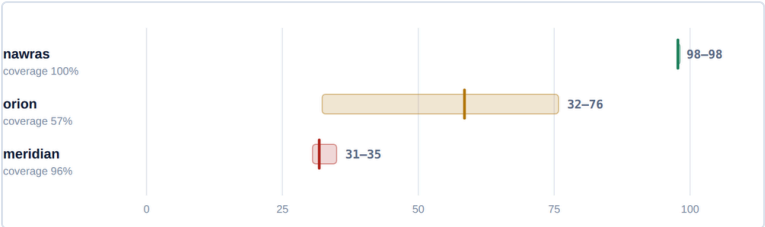
A BUG THE BUILD ENVIRONMENT TAUGHT US

This tool was built inside a network whose egress gateway terminates and re-issues TLS. A naive collector there reports a **perfectly healthy certificate for every host on the internet** — because it is describing the middlebox. Bayyina now detects that two ways, including the structural giveaway that unrelated bidders share one certificate issuer, and **withholds the finding rather than reporting a number it cannot stand behind**.

Results and conclusions

THE DEMONSTRATION TENDER — MDG-2026-114

Three bidders for a citizen case-management platform. **Meridian** submits the strongest paper bid: ISO 27001, SOC 2 Type II, a near-perfect questionnaire. **Nawras** submits less. **Orion** is barely observable from outside.



The bar is the range the evidence supports; the tick is the point estimate over observed evidence only. Where two bars overlap, the tool does not rank those bidders against each other.

BIDDER	POINT RANGE	SUPPORTED EVIDENCE COVERAGE	ATTESTATIONS CONTRADICTED	ATTESTATION RELIABILITY (95% CI)	CONDITIONS PRECEDENT
Nawras Digital DMCC nawrasdigital.example · MDG-2026-114/BID-02	97.75 98 – 98	100%	0 / 15	100% (74%–100%) 11 of 11 evidence sources	0
Orion Systems Integration LLC orionsys.example · MDG-2026-114/BID-03	58.51 32 – 76	57%	3 / 6	75% (30%–95%) 3 of 4 evidence sources	3
Meridian Gov Solutions FZ-LLC meridiangov.example · MDG-2026-114/BID-01	31.78 31 – 35	96%	10 / 16	27% (10%–57%) 3 of 11 evidence sources	10

Result: the paper favourite is overturned, and the tool can say exactly why

10 of Meridian's 16 externally testable attestations are contradicted by evidence — a claimed enforcing DMARC policy published at p=none; claimed TLS 1.0/1.1 removal on endpoints that still accept both; a claim that no administrative service is internet-facing, against RDP and an unauthenticated Elasticsearch 6.8 in the passive exposure data; a claimed absence of sub-processor incidents against a 2024 compromise through a third-party CRM; and an ISO 27001 certificate whose scope covers “managed IT support services ... from the Dubai office” — not the entity that would deliver the contract.

Those 16 claims rest on **11 independent evidence sources**, of which 3 corroborated everything resting on them — an estimated attestation reliability of **27% (95% CI 10–57%)**. Twenty further responses could not be tested externally, and nothing here supports treating them as more reliable.

PROVENANCE AND HONESTY

The three bidders are fictional; their domains are reserved under RFC 2606 and all 45 observations were generated by `scenarios/build_demo.py`. Real findings about real named companies would assert things they cannot rebut, and a live run cannot be reproduced later. The scenario deliberately exercises three distinct outcomes, so the contrast is sharper than a typical bid field; its attestation evidence comes from the real collector and registry. Sources: `docs/EVIDENCE.md`.

CONTROL	CLAIM	OBSERVED	SEVERITY
CAIQ v4 IVS-09	Are deprecated TLS versions (1.0 and 1.1) disabled on all Internet-facing services? Attested: Deprecated TLS versions are disabled = True	TLSv1, TLSv1.1 accepted on meridiangov.example	HIGH
CAIQ v4 SEF-08	Is DMARC published and set to an enforcing policy (quarantine or reject) on your corporate domain? Attested: DMARC is published at an enforcing policy = True	DMARC published at p=none — monitoring only, blocks nothing	HIGH
CAIQ v4 SEF-09	Is SPF published with a hard-fail terminator on your corporate domain? Attested: SPF is published and enforcing = True	SPF exceeds the RFC 7208 10-lookup limit (11); receivers ignore it	MEDIUM

Nawras — ranked first, defensibly

Interval **98–98**, coverage 100%, **zero contradictions in 15 testable claims across 11 evidence sources**. Reliability 100% (95% CI 74–100%) — a small perfect sample is still reported as an interval, not as certainty. Leader in 100% of 2,000 perturbed weightings and under every criterion removal.

Orion — not ranked

Its endpoint requires client-certificate authentication, so three TLS checks are genuinely unobservable; the CT query timed out; there is no incident record and no exposure data. Coverage **57%** — below the two-thirds threshold at which the tool considers a point estimate worth reading, and it says so. Interval **32–76**. Rather than invent a ranking, it emits **12 information requests** naming what would resolve it.

Concentration

Meridian and Orion share **authoritative DNS, edge/CDN and mail exchange**. A split award between them would not create independent failure domains — a fact no per-vendor rating can surface, because each rates one company alone.

WHAT THE BUYER DOES DIFFERENTLY ON MONDAY

- **The award is defensible.** One bidder is ranked first and the evidence separates it; two are declared inseparable rather than ordered on noise.
- **Each bidder can be handed a report** carrying the raw observation behind every finding — which is what Art. 29 asks for.
- **Ten conditions precedent** attach to the favourite before any award, each naming the attestation it corrects and the check that re-tests it.
- **Thirteen conditions precedent and thirty-six contract conditions** across the field, each with a severity-sized window and a machine-checkable acceptance test.
- **The split-award plan changes**, because two of the three bidders are not independent.
- **Re-running the same checks** after award turns each condition into continuous monitoring rather than a one-off gate.

NEXT

Bidder self-service — let a supplier run the assessment on itself before bidding, so the tool reduces the compliance burden it inspects rather than adding to it. **Arabic reporting**, and mapping the catalogue to UAE IAS and DESC ISR control identifiers so a finding cites the control a Dubai evaluator already works to.